Trạng thái	Đã xong
Bắt đầu vào lúc	Chủ Nhật, 17 tháng 5 2026, 4:31 PM
Kết thúc lúc	Chủ Nhật, 17 tháng 5 2026, 4:31 PM
Thời gian thực hiện	6 giây
Điểm	0,00/30,00
Điểm	**0,00** trên 10,00 (**0**%)

Câu hỏi **1**

Không trả lời

Đạt điểm 1,00

Một cuộc kiểm toán gần đây phát hiện có điểm yếu trong quy trình triển khai máy chủ mới và thiết bị mạng mới. Thực hành nào sau đây có thể được dùng để tăng mức độ bảo mật trong quá trình triển khai? Chọn 2 đáp án.”

A recent audit had revealed weaknesses in the process of deploying new servers and network devices. Which of the following practices could be used to increase the security posture during deployment? (Select TWO).

Select one or more:

- a. Disable unnecessary services — Tắt các dịch vụ không cần thiết
- b. Implement an application firewall — Triển khai tường lửa ứng dụng
- c. Penetration testing — Kiểm thử xâm nhập
- d. Change default password — Đổi mật khẩu mặc định
- e. Deploy a honeypot — Triển khai bẫy honeypot

giải thích: Khi triển khai server mới hoặc thiết bị mạng mới, việc quan trọng nhất là hardening — tức là cấu hình bảo mật cơ bản trước khi đưa vào sử dụng.

Your answer is incorrect.

The correct answers are: Disable unnecessary services, Change default password

Câu hỏi 2

Không trả lời

Đạt điểm 1,00

A web server hosted on the Internet was recently attacked, exploiting a vulnerability in the operating system. The operating system vendor assisted in the incident investigation and verified the vulnerability was not previously known. What type of attack was this?

Select one:

a. Distributed denial-of-service

b. Botnet

c. Zero-day exploit

d. Denial-of-service

Your answer is incorrect.

The correct answer is: Zero-day exploit

Câu hỏi 3

Chiến lược giảm thiểu rủi ro nào giúp Ann áp dụng nguyên tắc least privilege?

Không trả lời

Đạt điểm 1,00

Which of the following risk mitigation strategies will allow Ann, a security analyst, to enforce least privilege principles?

Select one:

a. User rights reviews

b. Incident management

c. Risk based controls

d. Annual loss expectancy

Rà soát quyền người dùng

Least privilege = chỉ cấp quyền tối thiểu cần thiết.
Muốn kiểm soát quyền tối thiểu thì phải rà soát quyền người dùng để xóa quyền thừa.

Mẹo nhớ:
Least privilege → kiểm tra quyền user → User rights reviews.

Your answer is incorrect.

The correct answer is: User rights reviews

Câu hỏi 4

Biện pháp nào nếu triển khai đúng sẽ ngăn người dùng truy cập các file không liên quan đến nhiệm vụ công việc?

Không trả lời

Đạt điểm 1,00

Which of the following, if properly implemented, would prevent users from accessing files that are unrelated to their job duties? (Select TWO).

Select one or more:

- a. Time of day restrictions
- b. Mandatory vacation
- c. Separation of duties
- d. Job rotation
- e. Least privilege

Least privilege: user chỉ được cấp quyền đúng mức cần thiết cho công việc.
Separation of duties: chia nhiệm vụ/quyền hạn rõ ràng, tránh một người có quá nhiều quyền truy cập không cần thiết.

Mẹo nhớ:
File không liên quan công việc → giới hạn quyền → Least privilege + Separation of duties.

Your answer is incorrect.

The correct answers are: Separation of duties, Least privilege

Câu hỏi 5

Không trả lời

Đạt điểm 1,00

A recent audit has revealed weaknesses in the process of deploying new servers and network devices. Which of the following practices could be used to increase the security posture during deployment? (Select TWO).

Select one or more:

- a. Penetration testing
- b. Implement an application firewall
- c. Change default passwords
- d. Disable unnecessary services
- e. Deploy a honeypot

Your answer is incorrect.

The correct answers are: Disable unnecessary services, Change default passwords

Câu hỏi 6

Kỹ sư bảo mật thấy có traffic lạ từ một IP đang cố truy cập port 23. Port 23 không được dùng trong mạng. Nên làm gì để tăng bảo mật mạng về sau?

Không trả lời

Đạt điểm 1,00

A network security engineer notices unusual traffic on the network from a single IP attempting to access systems on port 23. Port 23 is not used anywhere on the network. Which of the following should the engineer do to harden the network from this type of intrusion in the future?

Select one:

- a. Disable unnecessary services on servers
- b. Disable unused accounts on servers and network devices
- c. Enable auditing on event logs
- d. Implement password requirements on servers and network devices

Tắt các dịch vụ không cần thiết trên server

Port 23 = Telnet, là dịch vụ truy cập từ xa không an toàn. Nếu mạng không dùng port này thì nên tắt dịch vụ Telnet/dịch vụ không cần thiết để giảm nguy cơ bị tấn công.

Your answer is incorrect.

The correct answer is: Disable unnecessary services on servers

Câu hỏi 7

Không trả lời

Đạt điểm 1,00

An analyst is reviewing a simple program for potential security vulnerabilities before being deployed to a Windows server. Given the following code:

```
void foo (char *bar)
{
  char random_user_input [12];
  strcpy (random_user_input, bar);
}
```

Which of the following vulnerabilities is present?

Select one:

- a. Backdoor
- b. Buffer overflow
- c. Integer overflow
- d. Bad memory pointer

Your answer is incorrect.

The correct answer is: Buffer overflow

Câu hỏi 8

Không trả lời

Đạt điểm 1,00

Sau khi đánh giá, kiểm toán viên đề xuất công ty hosting nên ký hợp đồng thêm với các nhà cung cấp Internet khác để có kết nối Internet tốc độ cao dự phòng. Lý do chính là gì? Chọn 2 đáp án.

After an assessment, auditors recommended that an application hosting company should contract with additional data providers for redundant high speed Internet connections. Which of the following is MOST likely the reason for this recommendation? (Select TWO).

Select one or more:

- a. To eliminate a single point of failure — Loại bỏ điểm lỗi duy nhất
- b. To allow for business continuity if one provider goes out of business — Đảm bảo doanh nghiệp vẫn hoạt động nếu một nhà cung cấp gặp sự cố/ngừng hoạt động
- c. To improve intranet communication speeds
- d. To allow load balancing for cloud support
- e. To allow for a hot site in case of disaster

Có nhiều nhà cung cấp Internet giúp hệ thống không phụ thuộc vào một đường truyền duy nhất. Nếu một nhà mạng lỗi, công ty vẫn có đường truyền khác để duy trì dịch vụ.

Your answer is incorrect.

The correct answers are: To allow for business continuity if one provider goes out of business, To eliminate a single point of failure

Câu hỏi 9

Không trả lời

Đạt điểm 1,00

A server administrator notes that a legacy application often stops running due to a memory error. When reviewing the debugging logs, they notice code being run calling an internal process to exploit the machine. Which of the following attacks does this describe?

Select one:

- a. Buffer overflow
- b. Cross site scripting
- c. Malicious add-on
- d. Zero-day

Buffer overflow xảy ra khi chương trình ghi dữ liệu vượt quá vùng nhớ cho phép, làm lỗi bộ nhớ và có thể cho hacker chạy mã độc để chiếm quyền hệ thống.

Mẹo nhớ:
Có từ memory error, legacy application, code being run/exploit → chọn Buffer overflow.

Your answer is incorrect.

The correct answer is: Buffer overflow

Câu hỏi 10

Không trả lời

Đạt điểm 1,00

Quản trị viên bảo mật đang điều tra một vụ xâm nhập server. Vụ xâm nhập xảy ra do zero-day attack nhắm vào một chương trình ứng dụng người dùng chạy trên server. Nên xem log nào?

A security administrator is investigating a recent server breach. The breach occurred as a result of a zero-day attack against a user program running on the server. Which of the following logs should the administrator search for information regarding the breach?

Select one:

- a. Authentication log
- b. Application log
- c. Setup log
- d. System log

Vì cuộc tấn công nhắm vào user program/application, nên thông tin lỗi, crash, hành vi bất thường sẽ nằm chủ yếu trong Application log.

Mẹo nhớ:
Tấn công vào ứng dụng/chương trình → xem Application log.

Your answer is incorrect.

The correct answer is: Application log

Câu hỏi 11

Không trả lời

Đạt điểm 1,00

Which of the following ports will be used for logging into secure websites?

Select one:

- a. 110
- b. 80
- c. 443
- d. 142

Your answer is incorrect.

The correct answer is: 443

Câu hỏi 12

Không trả lời

Đạt điểm 1,00

Khái niệm nào cho phép tổ chức nhóm nhiều server lại với nhau để cùng cung cấp một dịch vụ chung?

Which of the following concepts allows an organization to group large numbers of servers together in order to deliver a common service?

Select one:

- a. RAID
- b. Clustering
- c. Backup Redundancy
- d. Cold site

Clustering là gom nhiều server thành một cụm để cùng xử lý dịch vụ, giúp tăng hiệu năng và tăng tính sẵn sàng.

RAID: gộp nhiều ổ cứng, không phải nhiều server.
Backup Redundancy: dự phòng sao lưu dữ liệu.
Cold site: địa điểm dự phòng khi thảm họa xảy ra.

Nhiều server cùng cung cấp dịch vụ → Clustering.

Your answer is incorrect.

The correct answer is: Clustering

Câu hỏi 13

Không trả lời

Đạt điểm 1,00

Một user bên Human Resources được cấp một máy ảo desktop vốn thường dành cho nhân viên Accounting. Admin muốn tắt một số dịch vụ và xóa các nhóm kế toán mặc định trên máy ảo đó. Admin đang áp dụng best practice bảo mật nào?

A Human Resources user is issued a virtual desktop typically assigned to Accounting employees. A system administrator wants to disable certain services and remove the local accounting groups installed by default on this virtual machine. The system administrator is adhering to which of the following security best practices?

Select one:

- a. Patch Management
- b. Mandatory Access Control
- c. Operating System hardening
- d. Black listing applications

Tắt dịch vụ không cần thiết và xóa nhóm/tài khoản/quyền mặc định là hành động hardening để giảm lỗ hổng và giảm quyền thừa trên hệ điều hành.

Gia cố bảo mật hệ điều hành

Your answer is incorrect.

The correct answer is: Operating System hardening

Câu hỏi 14

Không trả lời

Đạt điểm 1,00

Which of the following ports is used for TELNET by default?

Select one:

- a. 22
- b. 23
- c. 20
- d. 21

Your answer is incorrect.

The correct answer is: 23

Câu hỏi 15

Không trả lời

Đạt điểm 1,00

Which of the following is an example of a false positive?

False positive = hệ thống báo có nguy hiểm, nhưng thực tế không có nguy hiể

Select one:

- a. A biometric iris scanner rejects an authorized user wearing a new contact lens.
- b. Anti-virus identifies a benign application as malware.
- c. A user account is locked out after the user mistypes the password too many times.
- d. The IDS does not identify a buffer overflow

Your answer is incorrect.

The correct answer is: Anti-virus identifies a benign application as malware.

Câu hỏi 16

Không trả lời

Đạt điểm 1,00

Tắt các dịch vụ không cần thiết, giới hạn quyền quản trị và bật kiểm toán/audit trên server là hình thức của cái gì?

Disabling unnecessary services, restricting administrative access, and enabling auditing controls on a server are forms of which of the following?

Select one:

- a. Cross-site scripting prevention
- b. Creating a security baseline
- c. System hardening Gia cố bảo mật hệ thống
- d. Application patch management

Giải thích ngắn:
System hardening là làm hệ thống an toàn hơn bằng cách giảm điểm yếu: tắt service thừa, hạn chế quyền admin, bật log/audit để theo dõi.

Mẹo nhớ:
Tắt dịch vụ thừa + giới hạn quyền + bật audit → System hardening.

Your answer is incorrect.

The correct answer is: System hardening

Câu hỏi 17

Không trả lời

Đạt điểm 1,00

Quá trình xóa các tài khoản và dịch vụ không cần thiết khỏi một ứng dụng để giảm rủi ro được gọi là gì?

Which of the following describes the process of removing unnecessary accounts and services from an application to reduce risk exposure?

Select one:

- a. Cross-site script prevention
- b. Application hardening
- c. Application patch management
- d. Error and exception handling

Giải thích ngắn:
Application hardening là làm ứng dụng an toàn hơn bằng cách loại bỏ tài khoản, dịch vụ, chức năng hoặc cấu hình không cần thiết để giảm điểm yếu bị khai thác.

Mẹo nhớ:
Xóa account/service thừa trong application → Application hardening.

Your answer is incorrect.

The correct answer is: Application hardening

Câu hỏi 18

Không trả lời

Đạt điểm 1,00

A vulnerability scan is reporting that patches are missing on a server. After a review, it is determined that the application requiring the patch does not exist on the operating system. Which of the following describes this cause?

Select one:

- a. False negative
- b. Baseline code review
- c. Application hardening
- d. False positive

Your answer is incorrect.

The correct answer is: False positive

Câu hỏi 19

Không trả lời

Đạt điểm 1,00

Which of the following is a software vulnerability that can be avoided by using input validation?

Select one:

- a. Incorrect input
- b. Error handling
- c. Buffer overflow
- d. Application fuzzing

Input validation là kiểm tra dữ liệu người dùng nhập vào có đúng định dạng, đúng kiểu, đúng giới hạn không. Nếu kiểm tra tốt thì tránh được lỗi do input sai/không hợp lệ.

Có input validation → chọn Incorrect input.

Your answer is incorrect.

The correct answer is: Incorrect input

Câu hỏi 20

Không trả lời

Đạt điểm 1,00

A malicious individual is attempting to write too much data to an application's memory. Which of the following describes this type of attack?

Select one:

- a. Buffer overflow
- b. SQL injection
- c. XSRF
- d. Zero-day

Your answer is incorrect.

The correct answer is: Buffer overflow

Câu hỏi 21

Không trả lời

Đạt điểm 1,00

If you declare an array as A[100] in C and you try to write data to A[555], what will happen?

Select one:

- a. Whatever is at A[555] will be overwritten
- b. Nothing
- c. There will always be a runtime error
- d. The C compiler will give you an error and won't compile

Your answer is incorrect.

The correct answer is: Whatever is at A[555] will be overwritten

Câu hỏi 22

Không trả lời

Đạt điểm 1,00

Admin được quyền cấu hình máy, cài phần mềm, bảo trì tài khoản user, nhưng không được thêm máy tính mới vào domain vì việc đó cần người có thẩm quyền cao hơn phê duyệt. Đây là ví dụ của nguyên tắc nào?

One of the system administrators at a company is assigned to maintain a secure computer lab. The administrator has rights to configure machines, install software, and perform user account maintenance. However, the administrator cannot add new computers to the domain, because that requires authorization from the Information Assurance Officer. This is an example of which of the following?

Select one:

- a. Rule-based access control
- b. Job rotation
- c. Mandatory access
- d. Least privilege

Admin chỉ được cấp những quyền cần thiết cho công việc, không được cấp thêm quyền không cần thiết như thêm máy vào domain.

Mẹo nhớ:
Chỉ cấp quyền vừa đủ để làm việc → Least privilege.

Your answer is incorrect.

The correct answer is: Least privilege

Câu hỏi 23

Không trả lời

Đạt điểm 1,00

Biện pháp kiểm soát phòng ngừa nào phù hợp để giảm bề mặt tấn công của một máy/host cụ thể?

Which of the following preventative controls would be appropriate for responding to a directive to reduce the attack surface of a specific host?

Select one:

- a. Installing anti-malware
- b. Disabling unnecessary services
- c. Implementing an IDS
- d. Taking a baseline configuration

Attack surface là các điểm mà hacker có thể tấn công, ví dụ: port mở, service đang chạy, ứng dụng thừa. Tắt dịch vụ không cần thiết sẽ giảm số điểm có thể bị khai thác.

Mẹo nhớ:
Giảm attack surface → tắt thứ không cần → Disabling unnecessary services.

Your answer is incorrect.

The correct answer is: Disabling unnecessary services

Câu hỏi 24

Không trả lời

Đạt điểm 1,00

Kỹ thuật viên bảo mật IT cần thiết lập bảo mật dựa trên từng máy/host cho các máy trạm công ty. Cách nào đáp ứng tốt nhất?

An IT security technician needs to establish host based security for company workstations. Which of the following will BEST meet this requirement?

Select one:

- a. Implement database hardening by applying vendor guidelines.
- b. Implement OS hardening by applying GPOs.
- c. Implement IIS hardening by restricting service accounts.
- d. Implement perimeter firewall rules to restrict access.

Máy trạm công ty là các host/workstations, nên cần bảo mật ở mức hệ điều hành. Dùng GPO giúp áp dụng cấu hình bảo mật đồng loạt như mật khẩu, firewall, quyền user, khóa USB, audit log…

Mẹo nhớ:
Workstations + host-based security → OS hardening + GPOs.

Your answer is incorrect.

The correct answer is: Implement OS hardening by applying GPOs.

Câu hỏi 25

Không trả lời

Đạt điểm 1,00

Nếu kiểm thử chương trình C bằng cách nhập một chuỗi dài ngẫu nhiên và phát hiện buffer overflow, điều gì có khả năng xảy ra? Chọn một hoặc nhiều đáp án.

What is likely to happen if you find a buffer overflow during testing by entering a random, long string for a C program?

Select one or more:

- a. The program crashes
- b. The C fairy sprinkles magic memory dust on the memory that was overwritten and makes everything okay again.
- c. The program gives you a “Buffer overflow at line X” error
- d. Data is corrupted

Buffer overflow xảy ra khi dữ liệu nhập vào vượt quá vùng nhớ cho phép, làm ghi đè sang vùng nhớ khác. Kết quả thường là chương trình bị crash hoặc dữ liệu bị hỏng.

Mẹo nhớ:
Buffer overflow → tràn bộ nhớ → crash hoặc corrupt data.

Your answer is incorrect.

The correct answers are: Data is corrupted, The program crashes

Câu hỏi 26

Không trả lời

Đạt điểm 1,00

Which of the following provides the BEST application availability and is easily expanded as demand grows?

Select one:

- a. Server virtualization
- b. Active-Passive Cluster
- c. Load balancing
- d. RAID 6

Load balancing phân phối traffic cho nhiều server. Nếu một server lỗi, server khác vẫn xử lý được; khi nhu cầu tăng, có thể thêm server vào để mở rộng.

Mẹo nhớ:
Ứng dụng cần available + scalable → Load balancing.

Your answer is incorrect.

The correct answer is: Load balancing

Câu hỏi 27

Không trả lời

Đạt điểm 1,00

Ann, the software security engineer, works for a major software vendor. Which of the following practices should be implemented to help prevent race conditions, buffer overflows, and other similar vulnerabilities prior to each production release?

Select one:

- a. Product baseline report
- b. Input validation
- c. Patch regression testing
- d. Code review

Code review giúp kiểm tra mã nguồn trước khi release để phát hiện lỗi lập trình, lỗi xử lý bộ nhớ, lỗi logic, race condition, buffer overflow…

Mẹo nhớ:
Lỗi nằm trong code trước khi phát hành → chọn Code review.

Your answer is incorrect.

The correct answer is: Code review

Câu hỏi 28

Không trả lời

Đạt điểm 1,00

Which of the following protocols is the security administrator observing in this packet capture?
12:33:43, SRC 192.168.4.3:3389, DST 10.67.33.20:8080, SYN/ACK

Select one:

- a. SFTP
- b. HTTPS
- c. HTTP
- d. RDP

Your answer is incorrect.

The correct answer is: RDP

Câu hỏi 29

Data Execution Prevention (DEP) là tính năng trong hệ điều hành dùng để bảo vệ chống lại kiểu tấn công nào?

Không trả lời

Đạt điểm 1,00

Data execution prevention is a feature in most operating systems intended to protect against which type of attack?

Select one:

- a. Cross-site scripting
- b. Header manipulation
- c. Buffer overflow
- d. SQL injection

DEP ngăn không cho mã độc chạy trong vùng nhớ chỉ dùng để lưu dữ liệu. Tấn công buffer overflow thường cố ghi mã độc vào bộ nhớ rồi chạy nó, nên DEP giúp chặn kiểu tấn công này.

Mẹo nhớ:
DEP = chặn chạy mã trong bộ nhớ dữ liệu → chống Buffer overflow.

Your answer is incorrect.

The correct answer is: Buffer overflow

Câu hỏi 30

Không trả lời

Đạt điểm 1,00

Failure to validate the size of a variable before writing it to memory could result in which of the following application attacks?

Select one:

- a. Malicious logic
- b. SQL injection
- c. Buffer overflow
- d. Cross-site scripting

Nếu dữ liệu ghi vào bộ nhớ lớn hơn vùng nhớ được cấp, nó sẽ ghi tràn sang vùng khác. Đây là lỗi buffer overflow, có thể làm crash chương trình hoặc bị khai thác chạy mã độc.

Mẹo nhớ:
Có từ size, memory, writing to memory → chọn Buffer overflow.

Your answer is incorrect.

The correct answer is: Buffer overflow